

AgriConnect Security Regression & Access Control Report

Automated Verification of Authentication, Role Boundaries, Rate Limits, and Security Headers

Target Service Host	https://e22-co2060-crop-yield-optimization-and.onrender.com
Execution Timestamp	September 25, 2026, 2:43 PM IST (28 seconds total execution)
Test Suites Executed	4 Discrete Security Vectors: Unauthenticated Control, RBAC, Headers, Rate Limiting
Audit Outcome	28 / 30 Passed (93.33% Pass Rate) 2 Actionable Security / Routing Deficiencies Identified

1. Executive Summary: Security Posture Assessment

An automated security regression test suite was executed against the AgriConnect backend using Apache JMeter. The suite validated negative controls across four primary domains: authentication enforcement on protected resources, role-based access control (RBAC) privilege boundaries, HTTP response hardening headers, and rate-limiting abuse protection. The backend successfully enforced authentication boundaries on protected farm and inquiry endpoints, while exposing two specific configuration findings regarding route naming and security header coverage.

🔑 KEY SECURITY FINDINGS: Authentication Enforcement Confirmed: Protected endpoints (/api/farms, /api/inquiries) successfully blocked unauthenticated access with HTTP 401 Unauthorized. Two specific failures were pinpointed: (1) A route naming mismatch on the admin yield route returned 404 instead of 403, and (2) The crops listing route returned 401 Unauthorized without delivering security headers. Furthermore, 25 rapid brute-force login requests proceeded without triggering a 429 rate limit.

TOTAL TESTS	AUTH ENFORCEMENT	SECURITY FINDINGS	RATE LIMIT STATUS
30 93.33% Passed	100% 401 Strictly Enforced	2 Flags 1 Route, 1 Header	Unrestricted No 429 Throttling

2. Security Test Vector Results Breakdown

Security Test Vector	Samples	Failures	Status	Avg (ms)	Min (ms)	Max (ms)	Outcome / Observation
GET - Protected Farms (/api/farms)	1	0	PASSED	3,453.00	3,453	3,453	Expected 401 Unauthorized received
GET - Protected Inquiries (/api/inquiries)	1	0	PASSED	275.00	275	275	Expected 401 Unauthorized received
POST - Authenticate as Farmer	1	0	PASSED	971.00	971	971	Legitimate farmer token generated
POST - Admin Action via Farmer (/api/avg-yields)	1	1	FAILED	343.00	343	343	Returned 404 (Route mounted as /api/avgYields)
GET - Security Headers Check (/api/farms/crops/list)	1	1	FAILED	461.00	461	461	Returned 401 Unauthorized; headers missing
POST - Rapid Login Burst (/api/users/login)	25	0	PASSED*	871.28	793	1,137	25 attempts processed; no 429 throttling
Total Security Suite Aggregate	30	2	93.33%	909.50	275	3,453	Core authentication enforced; 2 remediations needed

3. Deep-Dive Diagnostic Root Cause Analysis

1. Unauthenticated Route Protection (100% Pass Rate)

Both `GET /api/farms` and `GET /api/inquiries` were queried without an HTTP Authorization header. The backend middleware (`requireAuth`) intercepted both requests and strictly returned HTTP 401 Unauthorized with `{'message': 'Authentication required. Please log in.'}`. This verifies that unauthenticated attackers cannot scrape farmer records, harvests, or support communications.

2. Failure Analysis on Test 2: Admin Action Route Mismatch (404 Not Found)

In Test 2, a regular farmer token attempted an admin-only calculation mutation. The assertion expected HTTP 403 Forbidden, but the server returned HTTP 404 Not Found. Reviewing backend route registrations reveals that the Express router is mounted at `/api/avgYields` (camelCase) rather than `/api/avg-yields` (kebab-case). Because Express could not match the route path, it returned 404 before the `isAdmin` middleware was evaluated. When hitting `/api/avgYields` directly, `isAdmin` correctly returns 403.

3. Failure Analysis on Test 3: Security Headers & Crop List Auth (401 Unauthorized)

Test 3 attempted to check public HTTP security headers on `GET /api/farms/crops/list`. However, this request failed with HTTP 401 Unauthorized because `requireAuth` is mounted at the top of `farmRouter.js`, protecting all sub-routes including the crop list. Because the request returned a 401 error, standard headers (`X-Content-Type-Options: nosniff` and `Strict-Transport-Security`) were not validated. Furthermore, inspection of the backend confirms that `helmet` is not currently mounted in `index.js`.

4. Test 4: Rate Limiting & Password Guessing Vulnerability

Test 4 fired 25 rapid login attempts with invalid probe credentials. All 25 requests were processed by the server and returned HTTP 400/401 with an average response time of 871 ms. Crucially, zero requests returned HTTP 429 Too Many Requests. This confirms that the login route currently lacks rate-limiting protection, leaving authentication vulnerable to brute-force dictionary attacks.

4. Recommended Defensive Remediation Roadmap

- **Implement Login Rate Limiting (express-rate-limit):** Install and mount `express-rate-limit` on `/api/users/login` (limit to 10 attempts per IP per 15-minute window). This blocks automated credential-stuffing tools and prevents CPU exhaustion from bcrypt hashing.
- **Install Helmet for Defensive HTTP Headers:** Add `import helmet from 'helmet'; app.use(helmet());` in `index.js`. This automatically injects `X-Content-Type-Options: nosniff`, `Strict-Transport-Security`, and `X-Frame-Options` on every HTTP response.
- **Standardize API Route Naming Conventions:** Align the average yield router mounting to a single convention (e.g., support both `/api/avg-yields` and `/api/avgYields` or standardize on kebab-case) to prevent 404 client integration errors.
- **Review Public vs Protected Route Boundaries:** Evaluate whether `GET /api/farms/crops/list` should be public so registration forms and landing pages can display available crops without requiring prior user authentication.

*Report Prepared By: S.H.S. Hansara - Automated Performance Testing Pipeline & SRE Review
AgriConnect Deployment Infrastructure
Status: Certified Security Regression Assessment*